

COI Automation Platform — Security Audit Report

Run 2 (Post-Remediation) · 2026-07-09 · Full codebase
Next.js 15 · BullMQ · Groq/LlamaParse · Prisma · Cloudinary · AgentMail

Executive Summary

Single-admin COI compliance platform. After fixing 17 original findings (SEC-001–SEC-017), posture improved to **moderate-to-good**. **3 HIGH** issues remain exploitable before production.

	Run 1	Run 2 (remaining)
HIGH	4	3
MEDIUM	9	8
LOW	4	7

Top 3 fixes: (1) Session revocation in middleware (2) Private Cloudinary URLs (3) Webhook sender from AgentMail API

Cursor prompt: Fix remaining findings POST-001 onward in docs/SECURITY-AUDIT-REPORT.md . Log changes in docs/SECURITY-AUDIT-FIXES.md .

Run 1 Remediation (SEC-001 → SEC-017)

ID	Status	Notes
SEC-001	Fixed	Accept/reject gates enforced on PATCH
SEC-002	Partial	Webhook secret yes; sender spoofing open
SEC-003	Fixed*	*Degrades without Redis
SEC-004	Fixed	Atomic dedup; claim-before-process side effect
SEC-005–013	Mostly fixed	See full report for partials
SEC-014–017	Mixed	CSP permissive; revocation gap

HIGH — Remaining Findings

POST-001: Revoked sessions still authorize API routes

Files	<code>middleware.ts</code> , <code>lib/auth-jwt.ts</code> , <code>lib/auth.ts</code>
Attack	Stolen cookie works after logout until JWT expiry (24h). Middleware skips Redis denylist.
Fix	Revocation check in middleware or <code>requireSession()</code> in all API handlers.

POST-002: COI documents public via Cloudinary URL

Files	<code>lib/services/cloudinary.ts</code> , dashboard UI, audit export
Attack	Anyone with URL downloads insurance docs without auth.
Fix	Authenticated/private assets + short-lived signed URLs.

POST-003: Webhook sender spoofing (SEC-002 incomplete)

Files	<code>webhook-intake.ts</code> , <code>agentmail.ts</code>
Attack	With webhook secret, forge <code>from</code> field → wrong tenant attribution.
Fix	Fetch sender from AgentMail API; ignore webhook JSON <code>from</code> .

POST-004: LLM fields in outbound templates (SEC-006 incomplete)

Files	<code>email-templates.ts</code> , <code>email-send.ts</code> , <code>agents.ts</code>
Attack	Adversarial PDF → extraction fields → platform-branded phishing email.
Fix	Sanitize template variables; guardrail on <code>suggestedEmailBody</code> .

MEDIUM — Remaining Findings

ID	Issue	Fix summary
POST-005	Webhook claim before process → permanent message loss	Release claim on failure
POST-006	Redis optional in prod → security controls noop	Require REDIS_URL in production
POST-007	Webhook auth off when secret unset (non-prod)	Fail closed on staging
POST-008	Webhook → missing_attachment email abuse	Rate limit auto-replies
POST-009	Unbounded message.text → LLM cost burn	Cap text length
POST-010	suggestedEmailBody no output guardrail	Block URLs/payment text
POST-011	guardrail_blocked emails leak internals	Tenant-safe template

LOW — Remaining Findings

ID	Issue
POST-012	X-Forwarded-For spoofing bypasses rate limits
POST-013	API 500 responses leak internal error messages
POST-014	CSP allows unsafe-inline / unsafe-eval
POST-015	LLM safety skipped for inputs ≤ 200 chars
POST-016	WORKER_FORCE_FAIL not blocked in production
POST-017	agent.py still deployable secondary surface
POST-018	PDF Content-Disposition filename not sanitized

Priority Matrix

Priority	IDs	Effort
P0	POST-001, POST-002, POST-003	2–3 days
P1	POST-004–POST-007	2 days
P2	POST-008–POST-011	1–2 days
P3	POST-012–POST-018	1 day

Positive Controls (Verified)

- JWT auth (HS256, httpOnly cookies, role check)
- Acceptance eligibility gates on accept route
- Atomic webhook dedup + production webhook secret
- Login rate limiting + bcrypt-only admin in production
- Magic-byte upload validation
- Outbound guardrails on all email paths
- Protected health endpoints
- Security headers + HSTS (production)
- Deterministic checklist reconciliation
- Prisma ORM only; HTML escaping in emails

Full detail: docs/SECURITY-AUDIT-REPORT.md · Remediation log: docs/SECURITY-AUDIT-FIXES.md ·
Generated 2026-07-09 Run 2